DeepL
Subscribe to DeepL Pro to translate larger documents.
Visit www.DeepL.com/pro for more information.

Objectives: Following on from the course on WiFi security, the objective of this first practical session is to gain a better understanding of the WEP protocol and learn how to carry out a full attack against this protocol. The attacks we will implement will enable us to retrieve a WEP key while understanding the theoretical basis of the different steps. Another objective is to understand the WPA and WPA2 protocols and some potential attacks against these protocols. The sub-objectives of this session are as follows:

- Getting started with Aircrack and its tools: airmon-ng, airodump-ng, aireplay-ng, and aircrak-ng
- Measuring WiFi channel listening ease and setting up packet capture
- Better understand WEP-PSK authentication and know how to perform a false authentication in different scenarios (with or without other clients)
- Know how to carry out packet injection attacks (ARP requests) and understand their purpose.
- Know how to find WEP keys and understand the theoretical basis behind them
- Understand WPA/WPA2 authentication through trace analysis.
- Capture and analyze key distribution packets (4-Way Handshake)
- Conduct a dictionary attack against WPA/WPA2
- Set up an illegal access point and understand the associated risks.

Keywords: *WEP, authentication, confidentiality, Aircrack, WEP key, initialization vector, RC-4, CRC, WPA, authentication, confidentiality, Aircrack, 4-Way Handshake, dictionary attack.*

Acknowledgments: Part of this practical assignment was inspired by the various tutorials available at https://www.aircrack-ng.org/doku.php?id=tutorial and by practical assignments prepared and taught by Matthieu Cunche (INSA-Lyon) and
Francois Lusieur (INSA-Lyon), whom I would like to thank.

1 Preamble

During this practical, we will use Yun boards, which are Arduino boards combining both Arduino and Linux. These boards are manufactured by Dog Hunter, a company specializing in the development of embedded Linux boards.

Yun boards feature an ATMega32U4 microcontroller clocked at 16 MHz and an Atheros AR9330 chip (IEEE 802.11n 1x1 2.4 GHz System-on-a-Chip (SoC)) suitable for wireless local area networks, access points, and routers, running on an OpenWRT-based Linux distribution.

2 Configuration

2.1 Connecting to Arduino Yun boards

Start by connecting to the Arduino Yun boards using a wired connection. The Ethernet interfaces of the Yun boards used in this lab are configured with static IP addresses.
192.168.44.2/24. Configure your PC's Ethernet interface with a network address of 192.168.44.0/24 and connect to the Yun via Putty. Log in as root (password: arduino).

2.2 Network card settings

Using the ifconfig command, display the settings (MAC address and IP address) of your wired and wireless interfaces

```
#ifconfig
```

Note these settings:

Using the iwconfig command, view the wireless interfaces on your card.

```
#iwconfig
```

The iwconfig command is similar to ifconfig but is dedicated to wireless interfaces. It can be used to set network interface parameters specific to wireless operations.

3 Network scan and packet capture

3.1 Starting the WiFi interface in monitor mode

Using the airmon-ng command, start the wlan0 interface in monitor mode. This mode allows you to capture all packets that pass through, including those that are not addressed to you.

```
#airmon-ng start wlan0
```

You can specify the channel number at the end of this command.

Using the iwconfig command, verify that a monitoring interface (called mon0 by default) has been created. This interface will be used for the rest of this practical exercise.

```
#iwconfig
```

From this point on, we will only use the mon0 monitoring interface. Turn off the wlan0 interface:

```
#ifconfig wlan0 down
```

3.2 Network scan and packet capture

Using the airodump-ng command, start scanning all wireless networks.

```
#airodump-ng mon0
```

Explain all the columns you see:

Using the help option, list the commands that allow you to filter networks by encryption type or by BSSID.

Before storing your new packets, it is advisable to delete the old traces on your SD cards.

Warning: Only delete files with the extensions csv, cap, netxml, and xor. The SD card contains folders that we will use later.

```
#cd /mnt/sda1
#rm *.csv *.cap *.netxml *.xor
```

The -w option allows you to save the captured packets to a file of your choice. Type the following command to save your packets.

```
#airodump-ng -c num - -bssid xx:xx:xx:xx:xx:xx -w /mnt/sda1/MyWEPCaptures mon0
```

Such as:
num is the channel number of the network named ReseauWEP xx:xx:xx:xx:xx:xx is the BSSID of the network named ReseauWEP (MAC of the AP).

IMPORTANT: From this step onwards, launch a new terminal and periodically check the progress of packet capture in the first terminal.

4 Replaying ARP requests from other clients

Capturing a large number of packets will be enough to crack the WEP key, as explained in the last section of this lab. To speed up the calculation of the WEP key, we will replay packets and inject new ones. If one or more clients are present on the network, simply capture one or more ARP requests and replay them, which will generate new IV initialization vectors. To do this, type the command:

```
aireplay-ng -3 -b xx:xx:xx:xx:xx:xx -h zz:zz:zz:zz:zz:zz mon0
```

Such as:

xx:xx:xx:xx:xx:xx is the BSSID of the network named ReseauWEP (MAC of the AP). zz:zz:zz:zz:zz:zz is the MAC address of a client that is already associated.

You should notice an increase in the number of data packets in the first terminal. What is the average number of data packets per second?

Now use the -x option and vary the value of this option from 10 to 800, for example. Again, note the average number of data per second in the first terminal. What is this option used for?

Remember that there are many of you, so you can set this value to 20, for example.

5 Injection of new ARP requests

IMPORTANT: If you manage to replay a large number of ARP requests and thus obtain a large number of IVs, statistical attacks (section 6) can be carried out without the need to inject new packets. If you are short on time during the practical, you can therefore skip directly to section 6. Otherwise, feel free to inject new packets as explained in this section.

In this section, you will learn how to inject your own ARP requests in order to speed up packet capture. In order to launch a packet injection, the malicious station must be associated and authenticated. In the following, we will begin by explaining how to perform a fake authentication and then move on to injecting ARP requests.

5.1 Performing a fake authentication

As seen in class, there are two possible authentication systems: WEP Open System and WEP Pre-Shared Key.

5.1.1 WEP Open System authentication

If the open authentication system is used, it is very easy to authenticate using the command

```
#aireplay-ng -1 0 -e WEPNetwork -h yy:yy:yy:yy:yy:yy mon0
```

Where:
yy:yy:yy:yy:yy:yy is your MAC address.

If the open authentication system is used, once authenticated, you can proceed to the next subsection (Section 5.2) to inject ARP requests.

5.1.2 Theoretical analysis of shared key authentication traces

However, most systems using WEP are based on shared key authentication.
As seen in class, this is based on the challenge/response principle.

To better understand shared key authentication, review your course material and analyze the file "wep.shared.key.authentication.cap."

By analyzing the first beacon, give the name of the SSID, the BSSID, the supported speeds, and the channel used for this scenario.

By analyzing the following packets (ignore the 802.11 acknowledgments), find the exchanges that allow authentication and association of the station with the wireless network.

5.1.3 Find the encryption suite in the case of shared key authentication.

In order to perform a false shared key authentication, you must first find the encryption suite. There are several ways to find this suite:

- Capture a real authentication request and deduce part of the cipher suite by applying an XOR between the challenge and the response (R1 XOR C1 = (keystream(key || IV1) XOR C1) XOR C1).
- Deliberately cause a disassociation of attached clients (or a client) and capture the new authentication request in order to deduce part of the cipher suite.

```
aireplay-ng -0 1 -a xx:xx:xx:xx:xx:xx mon0 (-c to specify a particular client)
```

- Use the Chopchop attack (currently known as the KoreK attack), which allows you to deduce the encryption suite byte by byte using the CRC.

To test this third method, run the command:

```
aireplay-ng -4 -a xx:xx:xx:xx:xx:xx -h zz:zz:zz:zz:zz:zz mon0
```

Such as:
xx:xx:xx:xx:xx:xx is the BSSID of the network named ReseauWEP (MAC of the AP). zz:zz:zz:zz:zz:zz is the MAC address of an already authenticated station.

You can use the -m option to specify the minimum packet size to use. To successfully perform the spoofed authentication, you must choose a packet with a large size T (1400). To speed things up, choose a small packet size instead, and the result of a long packet will be provided later.

If the attack is successful, the console displays "Completed" and two files are generated (a .cap file and an .xor file). Congratulations! It is the latter .xor file that contains the first T bytes of the cipher suite.

What is the average number of bytes discovered per second?

5.1.4 Launch the fake shared key authentication

Now that you have the beginning of the cipher block, you can easily launch a fake authentication to the access point. To do this, run the command:

```
aireplay-ng -1 0 -e WEPNetwork -y myfile.xor -a xx:xx:xx:xx:xx:xx -h yy:yy:yy:yy:yy:yy mon0
```

Such as:
myfile.xor is your .xor file or the replay_WEP file provided
yy:yy:yy:yy:yy:yy is your MAC address
xx:xx:xx:xx:xx:xx is the BSSID (MAC address of the access point)

What message is displayed?

5.2 Injecting ARP requests

Note the average number of data packets per second in the first terminal where packet and beacon capture is in progress.

Once your client is authenticated, you can inject arp requests using the command:

```
aireplay-ng -3 -b xx:xx:xx:xx:xx:xx -h yy:yy:yy:yy:yy:yy mon0
```

This command allows you to listen to ARP requests and inject them by setting your MAC address as the source address. The access point will rebroadcast these requests with new IVs each time, maximizing the number of IVs circulating on the network. You should notice an increase in the number of data packets in the first terminal. What is the average number of data packets per second?

6 Find the WEP key

When you stop capturing packets in the first terminal, a .cap file containing all the traces will be created. Based on this file (or files, if you have several), you can find the WEP key using the methods discussed in class. However, be careful; you often need at least tens of thousands of different IVs to find the key.

To find the key, run the command:

```
aircrack-ng -b xx:xx:xx:xx:xx:xx /mnt/sda1/*.cap
```

This will take into account all traces of all .cap files in the selected directory. You can, of course, specify a single file. How many different IVs did aircrack-ng find? What is the result of the command?

Well done! You have found a 128-bit WEP key (104+24). Enter this key.

The capture_WEP_more1.cap and capture_WEP_more2.cap files contain traces from two other networks (one with a 64-bit WEP key and the other with a 128-bit WEP key).

Run the command:

```
aircrack-ng capture_WEP_more1.cap
```

How many access points are affected by this capture? Choose the one that uses WEP and run the command with the -h option. How many different IVs did aircrack-ng find? What is the result of the command? Congratulations! You have found a 64-bit WEP key. Enter it.

Run the command:

```
aircrack-ng capture_WEP_more2.cap
```

How many different IVs did aircrack-ng find? What is the result of the command?
Well done! You have found a 128-bit WEP key. Enter it.

7 Theoretical analysis of WPA traces

The purpose of this section is to illustrate the different operational phases of WPA/WPA-2 through a detailed analysis of the traces available on the official AirCrack website.

7.1 Successful authentication

Open the wpa_full.cap file provided and analyze the different packets by answering the following questions: What is the role of packet 1 (beacon frame)? What is the main information that can be found in the IEEE 802.11 wireless LAN management frame field -> Tagged parameters?

What is the role of packets 2 and 3 (probe request and probe response)? What is the main information that can be found in IEEE 802.11 wireless LAN management frame –> Tagged parameters?

Will unicast and multicast encryption be provided using TKIP or CCMP?

Packets 4 and 5 are the request and response from the "open authentication system." The response is always positive.

What is the role of packets 6 and 7? What is the main information found in IEEE 802.11 wireless LAN management frame –> Tagged parameters?

Find the field that mentions the type of authentication: WPA-PSK (personal) or WPA-EAP (enterprise).

The packets you have analyzed so far correspond to phase 1 (security policy agreement) of the 802.11i operational phases (see course). In this scenario, we are using a shared key: WPA-PSK (WPA-Personal), which is why phase 2 (802.1x authentication) is not implemented. We will now look directly at the exchanges in phase 3 (key derivation and distribution).

What do packets 8 to 11 correspond to?

Give the first 5 bytes of the two random values proposed by the client and the access point.

What do packets 12 to 15 correspond to?

Identify ICV initialization vectors? How are they managed?

7.2 Authentication failed

We will now analyze the case of an unsuccessful authentication. Open the wpa_bad_password.cap file. Is there a difference in the first packets (1 to 7)? Why?

Analyze packets 8 and 9. How does the access point deduce that the client does not have the correct secret?

How many attempts are offered to the client?

8 Capture of WPA authentication (WPA handshake packets)

Now let's get back to the practical part by trying to carry out attacks against WPA/WPA2 using Aircrack. In order to capture WPA handshake packets, you need to start packet capture and wait in the hope that a client will connect to the network. Otherwise, trigger the deauthentication of an already authenticated client in order to provoke a new authentication request.

To trigger the associated deauthentication, run the command:

```
aireplay-ng -0 1 -a xx:xx:xx:xx:xx:xx -c zz:zz:zz:zz:zz:zz mon0
```

Such as:
xx:xx:xx:xx:xx:xx is the BSSID of the network named ReseauWPA (MAC of the AP). zz:zz:zz:zz:zz:zz is the MAC address of a client that is already associated.

What message is displayed?

Feel free to run this command several times if you do not see any WPA handshake packets.

9 WPA dictionary attack

One of the most commonly used attacks against WPA is the dictionary attack. Why do you think that is?

To launch a dictionary attack, the idea is to test all the secrets included in a given dictionary. Reviewing the details of the first two packets of the WPA handshake, explain the steps to follow in a dictionary attack against the WPA protocol.

Launch a dictionary attack using aircrack-ng.

```
aircrack-ng -w rockyou.txt -b xx:xx:xx:xx:xx:xx file.cap
```

Where:
xx:xx:xx:xx:xx:xx is the BSSID of the network named ReseauWPA (MAC of the AP). rockyou.txt is a dictionary (one of the most commonly used dictionaries) file.cap is your file containing the WPA handshake.

Ps:

- You can run aircrack-ng without specifying the BSSID of the network to attack. aircrack-ng will provide you with a list of all networks.
- Ideally, run aircrack-ng using your .cap file, but if you are unable to capture the handshake, run aircrack-ng on the provided capture_WPA_handshake.cap file, which was captured using the same network (same SSID, BSSID, and WPA key).

Congratulations! You have found the WPA key. Make a note of this key.

What is the average number of keys tested per second?

Yun cards have limited computing capabilities. Assuming that a computer is 1,000 times faster and knowing that complete French (and English) dictionaries contain approximately 100,000 (and 200,000) words, how long would it take to scan all the words in French? In English? In the RockYou dictionary?

Other dictionaries of the most commonly used passwords are available on the internet. You can download some of them and test them.

10 Rogue Access Point

One of the most dangerous attacks is the rogue access point attack. This attack can take several forms, two of which we will test:

10.1 Karma attack

In this attack, the access point responds to all probe requests regardless of the SSID specified in the request. To enable this mode, use the command:

```
airbase-ng -c 11 -P -C 60 -v mon0
```

What messages do you see?

10.2 AP spoof attack

Another attack involves setting up an illegal access point while specifying one or more SSIDs. To launch this attack, use:

```
airbase-ng -c 11 -e "public_network" -v mon0
```

What do you think would be the best SSIDs to choose?

Use the -E option instead of -e to announce multiple networks

In order to maximize the amount of information captured through this attack, it is ideal to be able to provide different clients with internet access. Explain the different steps to provide internet access to associated clients.

Once the rogue access point is set up, you can capture all traffic. What sensitive information can you capture? To gauge the sensitivity of this attack, analyze the FTP traces provided.